

InvestSmart Security Information

InvestSmart Security Information

Project: InvestSmart Financial Management and Investment Recommendation System

Purpose

This document records the security model used by the InvestSmart system, including roles, default demo users, password handling, OTP handling, and access control rules.

User Roles

1. client

Normal users are registered as clients. They can access only their own profile, finances, calculator results, saved investment plans, and personal report.

Client-accessible pages:

- Dashboard
- Profile
- My Finances
- Investment Calculator
- My Plans
- My Report

2. admin

Administrators manage the system. They can view system analytics, manage users, manage banks/providers, view reports, and inspect activity logs.

Admin-accessible pages:

- Admin Dashboard
- Manage Users
- Manage Providers/Banks
- Admin Reports

Default Admin Account

Email: admin@investsmart.local

Password: password

Role: admin

Status: active

Normal User Accounts

Normal users are created from the Sign Up form. The system does not require one fixed default client account because each client registers their own details.

Example test client account for demonstrations:

Full Name: Demo

Surname: Client

ID Number: 0001015009087

Email: client@investsmart.local

Password: password

Role after registration: client

Status after registration: active

Note: If this demo client is needed, create it from the Sign Up page before testing. The database script only seeds the administrator and bank/provider records.

Password Security

- Passwords are not stored as plain text.

InvestSmart Security Information

- PHP password_hash() is used to store hashed passwords.
- PHP password_verify() is used during login.
- Administrators can issue a temporary password when resetting a user password.
- Users can use Forgot Password with OTP to create a new password.

OTP Security for School Demonstration

InvestSmart uses OTP verification for login and password reset. Because this is a school project and email/SMS delivery is not required, the OTP is displayed on the screen for demonstration purposes.

Login flow:

1. User enters email and password.
2. Backend verifies the password.
3. Backend creates a one-time OTP.
4. OTP is shown on the screen.
5. User enters the OTP.
6. Backend verifies the OTP.
7. Backend creates an auth token.
8. User is redirected based on role.

Forgot password flow:

1. User opens Forgot Password.
2. User enters email address.
3. Backend generates a password reset OTP.
4. OTP is shown on the screen.
5. User enters OTP and a new password.
6. Backend verifies OTP and updates password hash.

OTP Storage Rules

- OTP values are hashed before being stored in auth_otps.
- OTP records include a purpose: login or password_reset.
- OTP records expire after a short time.
- Used OTP records are marked as used.
- Failed attempts are counted.

Session and Token Security

- The backend issues an authentication token after OTP verification.
- Tokens are stored in the auth_tokens table as hashes.
- API requests require the token for protected endpoints.
- Admin endpoints require role = admin.
- Client endpoints require role = client or the authenticated user's own data.

Access Control Summary

- A client can only view and update their own information.
- A client cannot access admin dashboard, user management, provider management, or admin reports.
- An admin can manage users and providers.
- An admin can view system-wide analytics and audit activity.
- Logout removes the frontend token and ends the user's active session from the browser side.

Audit Trail

Important user and admin activities are recorded in activity_logs. This supports accountability and makes the system more professional for assessment.

InvestSmart Security Information

Examples of logged actions:

- register
- login_otp_verified
- password_reset_otp_requested
- password_reset
- update_profile
- save_financial_profile
- save_investment_plan
- create_bank
- update_bank
- delete_bank
- change_user_status
- reset_password

Security Notes for Submission

- This system is suitable for a student demonstration environment.
- Production deployment should send OTPs through email or SMS instead of displaying them on screen.
- Production deployment should use HTTPS, secure cookies, rate limiting, server-side sessions, and stronger password policies.
- Default demo passwords should be changed before real-world use.